

Framework	Control Category	Specific Control Required	Our Implementation	Status
NIST SP 800-190 A cybersecurity guideline that provides best practices for securing containerized applications and container environments	Image Security	Vulnerability scanning before deployment	Trivy gate (CRITICAL, exit-code 1) in GitHub Actions pipeline	Implemented
		Multi-scanner strategy	Trivy implemented. Grype + Clair designed, not implemented	Partial
		Image signing and integrity verification	Cosign keyless signing → Fulcio → Rekor. Signature verified at pipeline end	Implemented
		SBOM generation and tracking	Syft generates SPDX-JSON SBOM, attested via Cosign, stored in Rekor	Implemented
		Minimal base images / non-root	Multi-stage Dockerfile, non-root appuser	Implemented
	Registry Security	Image tag immutability	Signs and references by digest (sha256), not by tag	Implemented
		Continuous vulnerability monitoring on running images	No Trivy Operator scanning running workloads	Missing → Add Trivy Operator (production)
		Trusted registry enforcement	Kyverno string-match allows only ali20052025/secure-app	Partial — not cryptographic
		Cryptographic admission verification	verifyImages rule not implemented: string-match only	Missing → Add Kyverno verifyImages rule (production)
		Runtime threat detection	Falco modern eBPF, 11 custom rules across syscall + audit layers	Implemented
	Container Runtime	Container escape detection	setns, unshare, mount, pivot_root rules: all CRITICAL	Implemented
		Privilege escalation detection	setuid/setgid/capset rules: WARNING priority	Implemented
		Anomaly detection / behavioral analysis	Isolation Forest ML service, 5-feature vector, per-container baseline	Implemented
		Automated threat response	Python response engine: terminate (syscall) or quarantine (audit)	Implemented
		Container isolation / resource limits	PSS Restricted + Kyverno require-resource-limits (Enforce)	Implemented
	Orchestrator Security	RBAC least privilege	Service accounts scoped per namespace, response engine RBAC limited to demo-sec	Implemented
		RBAC violation detection	ClusterRoleBinding Created rule (k8s_audit, CRITICAL)	Implemented
		API server audit logging	K3s audit policy: RequestResponse on pods, RBAC, secrets, exec	Implemented
		Network segmentation	Default-deny-all NetworkPolicy in all 4 namespaces	Implemented
		Pod Security Standards	PSS Restricted on demo-sec/default, Privileged on infra namespaces	Implemented
		CIS Benchmark compliance	kube-bench Job, CIS 1.8, pass/fail per control	Implemented
		mTLS service-to-service encryption	Linkerd not implemented: forward design only	Missing → Add Linkerd (production)
		Secrets encryption at rest	Not configured: K3s default etcd, no encryption-at-rest verified	Missing → Configure etcd encryption provider (production)
NIST CSF 2.0 A cybersecurity framework that helps organizations manage, reduce, and improve cybersecurity risk through a structured, risk-based	GOVERN	Security policy documentation	5 platform security policies defined (image acceptance, runtime, network, audit, least privilege)	Implemented
		Roles and responsibilities	Service accounts, RBAC roles, namespace boundaries defined	Implemented
	IDENTIFY	Supply chain risk management	Cosign signing, Trivy scanning, SLSA L2 provenance, SBOM	Implemented
		Risk assessment process	No formal documented risk assessment process	Missing → Document risk register (production)
		Asset inventory	SBOM provides software component inventory per image	Implemented
		Vulnerability identification	Trivy pipeline scanning, Polaris workload scoring, kube-bench CIS	Implemented
		Configuration assessment	Polaris (workload scoring), kube-bench (cluster config)	Implemented
	PROTECT	Continuous asset monitoring	No Trivy Operator for continuous runtime CVE discovery	Missing → Trivy Operator (production)
		Access control / least privilege	PSS Restricted, Kyverno policies, RBAC scoped service accounts	Implemented
		Supply chain integrity	Cosign keyless, SBOM attestation, provenance attestation, Rekor	Implemented
		Network segmentation	Default-deny NetworkPolicy, explicit allow rules per service path	Implemented
		Secure configuration enforcement	Kyverno Enforce policies, PSS Restricted, CIS Benchmark hardening	Implemented
	DETECT	Encryption in transit	NetworkPolicy controls paths but no mTLS: traffic unencrypted on allowed paths	Partial → Linkerd mTLS (production)
		Encryption at rest	Not implemented	Missing → etcd encryption (production)
		Vulnerability remediation	Manual remediation after Trivy gate. No auto-patching implemented	Partial → Trivy Operator auto-rebuild (production)
		Continuous monitoring	Falco eBPF syscall monitoring + K8s audit log monitoring	Implemented
		Anomaly detection	Isolation Forest ML, 5-feature vector, per-container baseline	Implemented
		Security event logging	Loki (audit logs + container logs), Prometheus (security metrics)	Implemented
		Security dashboards	Grafana Dashboard 1 (metrics) + Dashboard 2 (audit trail)	Implemented
		Alert generation	Falco alerts → Falcosidekick → response engine + ML + Sidekick UI	Implemented
		Automated alerting / paging	Alertmanager disabled: no PagerDuty/OpsGenie integration	Missing → Enable Alertmanager (production)
		Incident response plan	Automated response: terminate (HIGH) or quarantine (MEDIUM) within 300ms	Implemented
	RESPOND	Incident classification	Response engine classifies syscall = HIGH, audit = MEDIUM automatically	Implemented
		Containment	Pod termination (grace=0) or label quarantine=true	Implemented
		Incident notification	Falcosidekick UI real-time stream. No external notification (Slack/email)	Partial → Alertmanager routing (production)

		Forensic evidence preservation	Loki preserves audit logs. Quarantined pods preserved. Terminated pods: evidence lost	Partial
		Documented IR procedures	Incident response flow defined on slides (Detection→Classification→Action→Notification→In	Implemented
	RECOVER	Service restoration	Clean image redeploy, quarantine label removed, post-incident review	Designed
		Backup and restore	No etcd backup, no Prometheus persistent storage, 24h Loki retention	Missing → Persistent storage + backup strategy (production)
		Post-incident review	Grafana audit trail enables timeline reconstruction	Implemented
DORA	ICT Risk Management	Identify and classify ICT risks	Falco rules mapped to MITRE ATT&CK, 5 platform security policies defined	Implemented
An EU regulation that helps financial organizations strengthen their digital operational resilience by managing ICT risks and ensuring they can withstand, respond to, and recover from cyber incidents.		Continuous monitoring	Falco + Prometheus + Loki + Grafana: full observability stack	Implemented
		Threat detection capability	Falco eBPF + ML anomaly detection + K8s audit monitoring	Implemented
		Vulnerability management	Trivy pipeline gate, Polaris scoring, kube-bench CIS	Implemented
		Third-party/supply chain risk	Cosign signing, SLSA L2, SBOM, provenance attestation	Implemented
	Incident Response	Automated incident containment	Pod termination or quarantine within 300ms	Implemented
		Incident classification	Syscall = HIGH (terminate), Audit = MEDIUM (quarantine): automated	Implemented
		Incident reporting / audit trail	Grafana Dashboard 2: full event timeline in Loki	Implemented
		ICT incident notification to authorities	No external notification system	Missing → outside platform scope → Alertmanager + SIEM (production)
	Operational Resilience	Availability and continuity	Single-node K3s: no HA, no failover	Missing → K3s HA or managed K8s (production)
		Backup and recovery	No etcd backup, Prometheus no persistence, 24h Loki	Missing → Full backup strategy (production)
		Recovery time objectives	Not formally defined	Missing → Define RTO/RPO (production)
	Digital Resilience Testing	Penetration testing / resilience testing	No formal penetration testing program	Missing → outside platform scope
	Governance	Board-level ICT governance	Outside platform technical scope	Not Applicable
		Vendor risk management documentation	Outside platform technical scope	Not Applicable
HIPAA	Technical Safeguard:	Unique user identification	RBAC with named service accounts per workload	Implemented
A U.S. law that establishes standards for protecting the privacy, security, and integrity of sensitive healthcare information.	Access Control	Automatic logoff / session controls	Outside platform scope (no user-facing application)	Not Applicable
		Least privilege access	PSS Restricted + Kyverno Enforce + RBAC scoping	Implemented
		Emergency access procedures	Quarantine label preserves pod for emergency investigation	Implemented
		Hardware/software activity logging	K3s audit log (pods, exec, RBAC, secrets) → Loki	Implemented
		Security event monitoring	Falco alerts → Loki + Grafana timeline	Implemented
		Log retention for compliance	24h only: HIPAA expects 6 years	Missing → 90-day+ retention, S3 backend (production)
		Image integrity verification	Cosign signing, digest-based references, Rekor transparency	Implemented
		Workload configuration integrity	Kyverno admission control prevents insecure config at deploy time	Implemented
		Data integrity at rest	No etcd encryption	Missing → etcd encryption (production)
		Encryption in transit	NetworkPolicy controls paths: no mTLS encryption on those paths	Partial → Linkerd mTLS (production)
		Authenticated transmission	Labels only: not cryptographic identity	Partial → Linkerd mTLS (production)
	Administrative Safeguard:	Formal risk assessment	Not implemented: outside platform technical scope	Not Applicable
	Risk Analysis	Security policy management	5 platform policies defined technically. No formal HR/legal policies	outside scope
		Security awareness training	Outside platform scope	Not Applicable
		Disaster recovery plan	Not formally documented	Missing → Document DR plan (production)
	Physical Safeguard	Physical access controls	Outside platform scope (VMware/datacenter controls)	Not Applicable